

한전KDN(주) 상임감사 개선 요구

제 목 정보시스템 위탁운영 보안관리 부적절

소 관 부 서 ○○○○처(△△△△팀)

구 분 보안관리

내 용

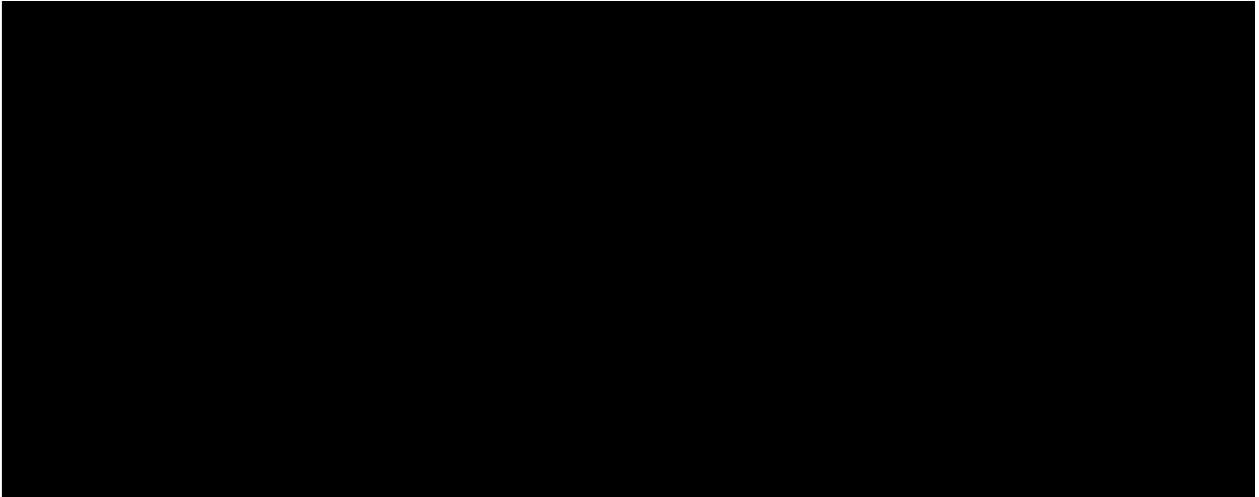
○○○○처 △△△△팀은 사내 정보시스템을 ERP시스템(재무회계 등 00종)과 Non-ERP시스템(사내포털시스템 등 00종)으로 구분하고 사내 정보시스템 개발 및 유지관리 업무를 수행하고 있다. 이와 관련하여 ERP시스템관리(BC)업무¹⁾와 급여시스템 일상운영 및 유지관리 업무를 외부로 위탁하는 “2016년도 사내정보시스템 ERP 유지관리 용역”계약을 △△△△△△△△과 2016. 5. 13 체결하였고, 사내포털시스템 등 20종의 일상운영 및 유지보수 업무를 외부위탁하는 “사내정보시스템 유지관리 용역”계약을 ○○○○○○과 2016. 12. 30 체결하였으며 용역업체 직원들은 △△△△팀과 다른 사무공간에서 위탁업무를 수행하고 있다.

△△△△팀 ERP시스템관리(BC) 업무를 담당하던 직원 ○○○○은 휴직을 앞두고 ERP시스템관리(BC) 업무 인계를 하기 위해 사용하던 슈퍼권한(***_***)이 부여된 시스템관리자 계정(○○○○○○○○)과 패스워드를 2016. 5. 13 ERP시스템관리(BC) 업무 인수를 받는 용역업체 직원 ●●●●에게 알려주어 이를 사용하도록 하고 ●●●●은 인수 받은 시스템관리자 계정(○○○○○○○○)의 패스워드를 2017. 3. 9까지 변경하지 않고 사용

1) ERP시스템관리(BC)업무 : ERP시스템의 권한설정, 운영환경 설정 등 ERP시스템 운영에 필요한 중요 설정을 관리하고 ERP시스템 운영상태 감시와 장애 조치를 수행함

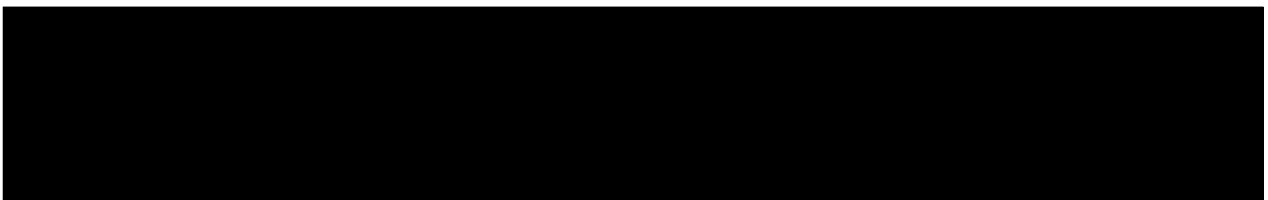
하고 있었다.(그림 1. 참고)

[그림 1] 시스템관리자 계정(👤👤👤👤👤) 패스워드 변경 내역



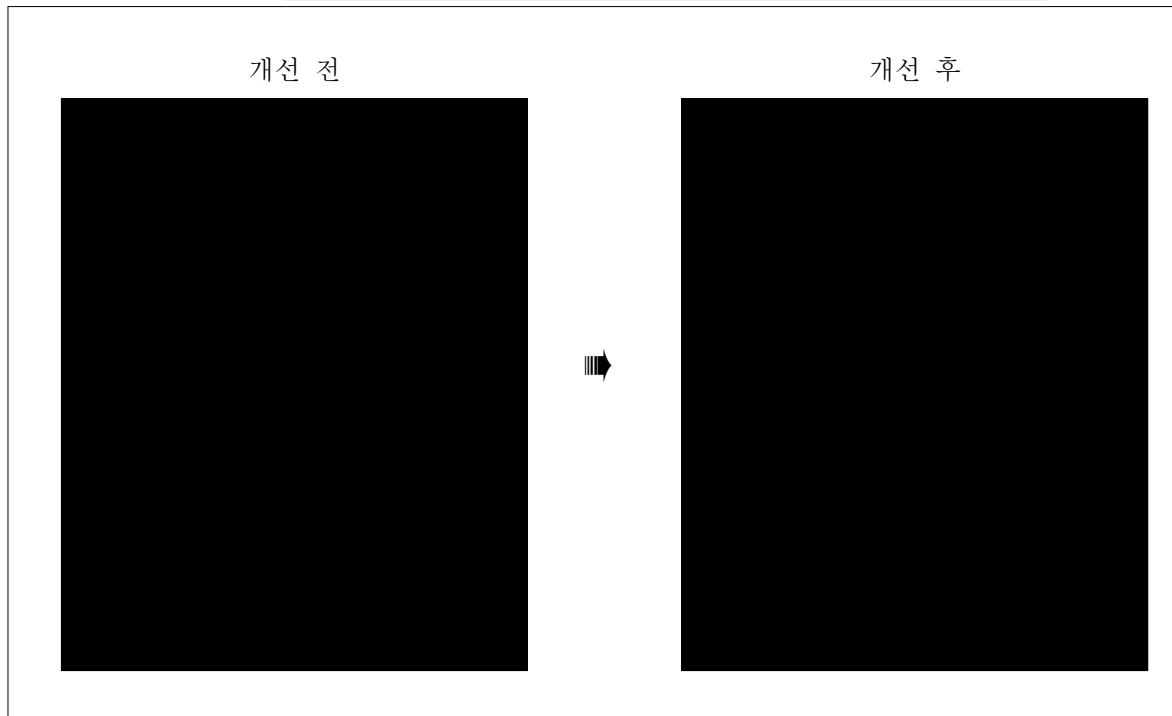
또한, 급여시스템 일상운영 및 유지관리 업무를 위탁받아 운영하는 용역업체 직원 👤👤👤에게 별도의 사용자계정 ⚙️⚙️⚙️⚙️를 만들어 사용하도록 하고, 슈퍼 권한과 상응하는 〇〇〇-〇〇-〇〇권한을 부여하고 위탁업무를 수행하게 하였다.(그림2. 참고)

[그림 2] 용역업체 직원 👤👤👤 사용자 계정(⚙️⚙️⚙️⚙️) 생성 및 권한 부여 내역



◁◁◁◁팀은 사내정보시스템 응용프로그램 관리체계 정립 및 보안강화를 목적으로 관리자 PC를 ◁◁◁◁팀 사무 공간에 설치하고 내부 직원(SW관리자)이 관리자 PC에서 운영 시스템의 응용프로그램을 변경하도록 “사내정보시스템 응용프로그램 운영 관리 절차 개선 및 보안강화”를 2015. 5. 26 부로 시행하며 SW관리자 업무는 직원 ◇◇◇이 수행하였다. 직원 ◇◇◇은 본인이 수행하던 SW관리자 업무를 인수인계하지 않고 타부서로 이동하여 2016. 1. 16 이후 운영 시스템의 응용프로그램 변경은 개선 전과 동일하게 용역업체 직원이 직접 운영시스템의 응용프로그램을 변경하였다.

[그림 3] 사내정보시스템 응용프로그램 운영관리 절차 개선



△△△△팀은 「정보보안 절차서」 4.4(사용자 관리), 6.3.14(용역사업 보안관리), 6.3.15(정보시스템 위탁운영 보안관리)에 따라 정보시스템에 대한 외부업체 위탁 운영을 최소화하고, 외부 인력을 활용하여 비밀 및 중요 외주 용역사업을 수행할 경우 외부 인력의 고의 또는 실수로 인한 정보의 유출이나 파괴를 방지하기 위한 외부인원에 대한 신원조사·비밀취급인가, 보안 교육 및 외부유출 방지 등의 보안 조치를 강구하여 관리적·물리적·기술적 보안대책을 수립하여 시행하여야 한다.

그러나, △△△△팀은 ERP시스템 유지관리 위탁 외부 용역업체 직원 ●●●과 ●●●에게 ERP 운영시스템 사용계정을 계정만료일도 지정하지 않고 ERP시스템의 모든 기능을 자유롭게 사용할 수 있는 슈퍼권한과 이와 상응하는 권한을 외부 직원에게 부여하고, Non-ERP시스템 또한, 내부 직원의 통제 없이 운영 시스템의 응용프로그램을 외부 직원이 직접 변경토록 하게 하는 등 정보시스템 보안관리가 부적절 하였다.

ERP시스템의 슈퍼권한(***_**)과 그에 상응하는 ○○○-○○-○○권한은 그

림4와 그림5와 같이 ERP시스템의 모든 기능을 자유롭게 사용할 수 있는 권한이며 그 위험성으로 인하여 특정 관리자에게만 부여하고 엄격한 관리통제가 되어야 하고, Non-ERP시스템의 운영서버 OS계정은 운영시스템의 응용프로그램을 직접 변경할 수 있어 한전 전산 입찰 비리와 같은 보안 사고의 위험에 노출될 우려가 있어 엄격히 통제하여야 한다.

[그림 4] 슈퍼권한(***_**)이 실행 가능한 트랜잭션 수

선택한 트랜잭션수: 112,700				
System	ECP	Client	100	Checked By 962348 2017.03.09 10:10:16
Selection Criteria:				
프로파일	SAP_ALL SAP 시스템에 대한 전체권한			

[그림 5] 권한 000-00-00이 실행 가능한 트랜잭션 수

선택한 트랜잭션수: 102,437				
System	ECP	Client	100	Checked By 022045 2017.03.27 11:17:49
Selection Criteria:				
Role	ZBC-00-00 PI Role			

조치할 사항

00000처장은 ① 사내 정보시스템 유지관리 및 일상운영과 관련하여 내부인력을 확보하여 외부업체 위탁운영을 최소화하시기 바랍니다. ② 외부업체 인력에 대하여 범죄사실 여부확인 등의 신원 확보 방안을 검토하고 수립하여 부적격한 외부업체 인력의 고의에 의한 정보 유출이나 침해를 방지하시기 바랍니다. ③ 외부업체 인력의 시스템 접근 권한은 업무 수행에 필요한 범위로 한정하여 부여하시기 바랍니다. ④ 시스템관리자와 그에 상응하는 계정의 사용 기록이 통제 될 수 있도록 보안 강화 대책을 수립하여 조치하시기 바랍니다.(개선)